

КОНФИДЕНЦИАЛЬНО · ДЛЯ ВНУТРЕННЕГО ИСПОЛЬЗОВАНИЯ

Библиотека компонентов @invoicebox/ui

Итоговый отчёт аудита
и план рефакторинга волнами

Дата аудита: 15 июня 2026
Безопасность и утечки данных: security@invoicebox.ru

Аудит библиотеки @invoicebox/ui — сводный отчёт

Самостоятельный отчёт для руководства и владельцев. Полная детализация по каждой проблеме — в документах `audit/00` — `audit/10` и трекере `CHECKLIST.md`.

Контекст

`@invoicebox/ui` — публикуемая в npm библиотека React-компонентов (UI-kit): ~38 компонентов (формы, общие элементы), темизация, валидаторы реквизитов РФ/СНГ. Это **не приложение** — нет роутинга, стора, серверной части. Поэтому «страничные» метрики (Lighthouse, Web Vitals, OAuth) неприменимы; аудит сфокусирован на том, что влияет на потребителей пакета: безопасность, доступность, вес поставки, типобезопасность API, тесты и процесс релиза.

Аудит выполнен 15.06.2026 на ветке `develop` (версия `0.1.0-alpha.292`), **до изменений кода**.

Оценка по направлениям

Направление	Оценка	Главное
Отказоустойчивость	🔴	0 try/catch, 0 ErrorBoundary во всей библиотеке
Безопасность (код)	🟡	непровалидированный <code>href</code> , regex-валидатор; секретов нет
Безопасность (зависимости)	🔴	83 уязвимости (3 critical, 31 high)
Размер и поставка	🟡	CJS-only без tree-shaking, мёртвая зависимость <code>motion</code>
Доступность (WCAG AA)	🔴	практически отсутствует (0 <code>aria / role</code>)
Качество API и типы	🟢	god-компонентов нет; точечные <code>any / eslint-disable</code>
Платформа и сборка	🟡	устаревшие TS/ESLint, ручной релиз без гейта
Тесты и CI	🔴	4 теста в 1 файле, CI нет

Базовая линия (метрики на старте)

Метрика	Значение
Тестов / тест-файлов	4 / 1
CI	отсутствует
Уязвимости (<code>npm audit</code>)	83 (critical 3, high 31, moderate 37, low 12)
Размер <code>dist</code>	2.4 MB (CJS, без минификации/tree-shaking)
Мёртвая prod-зависимость	<code>motion</code> ^12.38 (0 использований)
Компонентов / файлов / stories	~38 / 270 / 78
<code>any</code> / <code>@ts-ignore</code>	11 / 0
<code>try/catch</code> / <code>ErrorBoundary</code>	0 / 0
<code>aria-*</code> / <code>role=</code>	0 / 0
Секреты / <code>dangerouslySetInnerHTML</code>	0 / 0

Ключевые риски

1. **Нет CI и тестов критичной логики** (🔴). Валидаторы банковских реквизитов, ОГРН, контрольных сумм, денег и дат почти не покрыты; ничего не проверяется автоматически. Ошибка здесь тиражируется во все приложения-потребители. → 08
2. **83 уязвимости в зависимостях** (🔴, 3 critical). Почти все — из dev-цепочки Storybook 7 / `react-scripts` (CRA-пресет). Снимаются миграцией Storybook. → 03, 07
3. **Доступность близка к нулю** (🔴). Кастомные Select/Dropdown/Autocomplete/Toggle без клавиатуры и ARIA, модальки без фокус-трапа. Для библиотеки форм-инпутов — критично. → 05
4. **Непровалидированный href + target="_blank" без rel** в AppCardLink (🟡). Потенциальный DOM-XSS и tabnabbing. → 03
5. **CJS-only поставка без tree-shaking** + мёртвая motion (🟡). Потребитель тянет лишний вес. → 04
6. **Ручной релиз с локальной машины** без прогона тестов/линта/audit, публикация в npm и push в main без гейта (🟡). → 07

План рефакторинга (волнами, по приоритету риска)

- **Волна 0 — сетка безопасности.** CI (lint+test+build+audit), jest-конфиг и пороги покрытия, `size-limit`, a11y-линт (warn), удалить мёртвый motion.
- **Волна 1 — высокий риск.** Фикс href/XSS в AppCardLink; правка regex-валидатора; миграция Storybook 7→8/9 (минус десятки CVE); `node >=18`; тесты всех валидаторов.
- **Волна 2 — поставка и типы.** ESM+CJS сборка с `exports -map` и tree-shaking; апгрейд TS 5 / ESLint 9; убрать `any`; единый логгер и `onError`-хуки; компонентные тесты + a11y.
- **Волна 3 — доступность и качество.** Клавиатура+ARIA по компонентам, фокус-трап в модальных, контраст/таргеты, `prefers-reduced-motion`, `ErrorBoundary`, CLS-стабильность.

Требуют согласования до старта: миграция Storybook, смена сборщика и формата импорта, правки a11y-разметки (могут задеть стили потребителей), удаление motion, перенос релиза в CI. Бизнес-логика и публичный API не меняются без отдельного продуктового решения.

Положительное

God-компонентов нет (макс ~341 LOC), секретов в коде нет, `dangerouslySetInnerHTML` нет, `@ts-ignore` = 0, структура проекта здоровая и консистентная.